Specifica Architetturale Frontend Web App ERP Multi-Tenant

Versione 3.1 - Final Implementation Contract

Integrazione alla Specifica Tecnica v1.0 - Data documento: 19 agosto 2026

Stato	Decisione
Architettura	VALIDATA
Sviluppo	AUTORIZZATO
Go-live	NON AUTORIZZATO dalla sola specifica
Natura del documento	Contratto di implementazione verificabile; non certificazione né audit indipendente

Nota di controllo: le versioni devono essere confermate nel repository al momento dell'implementazione, fissate nel lockfile e aggiornate solo tramite change request, test di regressione e security review. Non usare release latest senza lockfile.

0. Decisione esecutiva

La v3.1 consolida la v3.0 e incorpora i principali rilievi di validazione tecnica esterna. Le scelte architetturali centrali restano confermate: backend come Source of Truth, RLS multi-tenant, TanStack Query per server state, RxDB per cache/outbox offline, Sync Coordinator come unico orchestratore, runtime validation, fiscalità definitiva esclusivamente backend e go-live subordinato a evidenze oggettive.

1. Baseline riproducibile

Componente	Baseline proposta	Regola di gestione
Node.js	22.x LTS	Pin con .nvmrc/.tool-versions e CI
React	19.2.x	Pin esatto nel lockfile; patch update controllato
Vite	8.x	Compatibilità Node e plugin verificata in CI
TypeScript	Versione fissata	strict, noImplicitAny, noUncheckedIndexedAccess
React Router	Major fissato	Scegliere e documentare una sola modalità: Data/Declarative/Framework
TanStack Query	v5.x	Configurazione e persistenza testate
RxDB	Versione fissata	Schema migrations, payload e conflitti versionati
Valibot	Versione fissata	Runtime validation ai confini
Testing	Vitest + Testing Library + Playwright	Versioni e browser/device matrix in CI

2. Principi di autorita

- PostgreSQL/Supabase e la sola Source of Truth per dati contabili, autorizzazioni effettive, numerazione fiscale, XML, submission e stati SDI.
- La publishable key puo stare nel browser secondo il modello RLS; secret/service-role keys e credenziali provider sono esclusivamente backend.
- organization_id ricevuto dal browser e un input non attendibile: appartenenza e ruolo derivano da sessione e membership server-side.
- Il frontend valida, propone e visualizza; il backend autorizza, ricalcola, persiste e applica transizioni atomiche.
- Realtime accelera l'aggiornamento UI ma non costituisce prova di persistenza o accettazione fiscale.
- Nessun segreto SDI, token provider o calcolo fiscale definitivo deve entrare nel bundle frontend.

3. Stato e confini

Dominio	Tecnologia	Vincolo
Server state	TanStack Query v5	Cache/query/realtime; nessuna autorita fiscale
Offline state	RxDB	Cache/outbox; retention, recovery e versioning obbligatori
UI state	Zustand/useReducer	Solo stato effimero; mai dati contabili autorevoli
Domain validation	Valibot	Input/output unknown validati prima del dominio
Sync	Sync Coordinator	Unico modulo autorizzato a orchestrare la sincronizzazione

4. Contract API

Ogni endpoint deve avere un contratto versionato, con schema request/response/error condiviso tra client e backend. Breaking changes tramite /api/v1 o equivalente; contract tests obbligatori.

SUCCESS
{ "ok": true, "data": {}, "meta": { "requestId":"...", "serverVersion":1 } }

ERROR
{ "ok": false, "error": { "code":"FORBIDDEN", "message":"safe", "retryable":false }, "meta": { "requestId":"..." } }

Categoria	Codici minimi
Transport	NETWORK, TIMEOUT, ABORTED
API/domain	AUTH_REQUIRED, FORBIDDEN, TENANT_MISMATCH, VALIDATION, CONFLICT, IDEMPOTENCY_REPLAY, IDEMPOTENCY_KEY_REUSE_CONFLICT, RATE_LIMITED, SERVER, PROVIDER, PERMANENT

- I messaggi client non devono contenere stack trace, segreti o dati personali non necessari.

5. Permission matrix minima

Modulo	Owner	Admin	Accounting	Warehouse	Viewer
Organizzazione/ membri	CRUD	CRUD	Read propria	No	No
Clienti/fornitori	CRUD	CRUD	CRUD	Read	Read
Prodotti/ magazzino	CRUD	Read	CRUD	CRUD	Read
Ordini	CRUD	CRUD	CRUD	Limitato	Read
Bozze fattura	CRUD	CRUD	CRUD	Read	Read
Validazione/invio SDI	Si	Si	Si	No	No
Audit	Read/export autorizzato	Read/export autorizzato	Read	No	No
Impostazioni provider	Si	Si	No	No	No

Ogni cella deve diventare un test Given/When/Then su API, RPC, RLS, UI e Realtime. La UI puo nascondere un'azione, ma l'autorizzazione reale deve fallire lato server. I significati di "Read propria" e "Limitato" devono essere definiti nella matrice di campo/attributo associata.

6. Conflict Resolution Matrix

Entita	Conflitto	Strategia obbligatoria	Accettazione
Customer	Campi non sovrapposti	Merge deterministico se versione base coincide	Evento audit + nuova versione
Customer	Stesso campo	Server-wins	Mai overwrite silenzioso
Product	Prezzo/aliquota	Server-wins	Cache invalidata; utente vede differenza
Order draft	Righe/quantita simultanee	Manual resolution	Nessun invio finche irrisolto
Invoice draft	Campo fiscalmente rilevante	Reject + manual resolution server-side	Outbox bloccato
Submitted/accepted invoice	Qualsiasi conflitto	Mai merge locale; sola autorita server	Errore permanente + audit

La risoluzione usa entity_version BIGINT generata dal server. Non usare esclusivamente client clock o updated_at per decidere l'ordine delle versioni. Per ogni strategia deve esistere un solo comportamento deterministico nella versione corrente del contratto.

7. Outbox e Sync Coordinator

- Un solo Sync Coordinator per origin tramite leader election; ogni item mantiene lease persistente e fencing token/lease generation.
- Pipeline: local atomic write -> idempotency key -> session/tenant check -> API -> backend transaction -> response validation -> outbox update -> query invalidation/reconcile.
- Stati: pending, processing, retry_wait, succeeded, failed.

- Alla scadenza del lease, il job torna retry_wait con backoff e jitter. Un worker stale non deve poter completare una mutazione dopo la perdita della leadership.
- NETWORK e failure temporanei sono ritentabili; VALIDATION, FORBIDDEN, TENANT_MISMATCH e conflitti sono permanenti finche l'utente non interviene.
- Ogni mutation porta operation, payloadVersion e schemaVersion compatibili con la versione dell'app che l'ha generata.

8. Idempotency contract

- Una stessa idempotency key con lo stesso request hash deve restituire lo stesso risultato logico senza duplicare la mutazione.
- La stessa idempotency key con request hash diverso deve produrre IDEMPOTENCY_KEY_REUSE_CONFLICT.
- Il backend deve persistere organization_id, operation, idempotency_key, request_hash, stato, risultato e timestamp in modo transazionale.
- La retention delle idempotency records e il relativo TTL devono essere configurati e testati; il TTL non puo essere inferiore alla finestra massima in cui il client puo ritrasmettere una mutation.
- La risposta di replay deve essere semanticamente equivalente a quella originaria e auditabile tramite requestId/correlationId.

9. Storage, GDPR e device recovery

Collection	PII	Finalita	Retention	Logout/device loss	Delete/export
customer_cache	Si	UX offline	Configurata; max necessaria	Clear + revoke device	Export/clear documentati
supplier_cache	Si	UX offline	Configurata	Clear + revoke device	Export/clear
product_cache	Potenziale	UX offline	Configurata	Clear	Clear
order_drafts	Potenziale	Bozza operativa	Fino a sync/retention	Preserve/recover	Export prima clear
invoice_drafts	Si	Preparazione fiscale	Policy fiscale	Preserve/recover; accesso controllato	Policy approvata
outbox_items	Potenziale/si	Sync	Fino a esito + retention	Preserve/recover	Export protetto
dead_letter	Potenziale/si	Recovery/audit	Retention definita	Preserve/recover	Accesso autorizzato

I valori di retention, le procedure di cancellazione/anonimizzazione e le regole di accesso devono essere approvati dal titolare/DPO e coordinati con gli obblighi fiscali e legali. Il browser storage e soggetto a quota ed eviction: non promettere conservazione indefinita offline.

- Soglia warning storage e soglia critical storage devono essere configurate per ambiente/browser matrix.
- A quota critica: bloccare nuovi allegati, avvisare, offrire export/recovery e non cancellare pending senza procedura verificata.

- Device recovery minimo: revoke session server-side -> stop coordinator -> export cifrato se consentito -> reinstall -> login -> bootstrap server -> riallineamento per entity_version -> report operazioni irrecuperabili.

Per export cifrati devono essere definiti formato, algoritmo, gestione chiavi, autorizzazione, import/recovery e invalidazione. Il browser non e un archivio primario.

10. Money e fiscalita

Il contratto deve essere chiuso prima dello sviluppo fiscale. Il frontend puo usare rappresentazioni intermedie solo se coerenti con il contratto condiviso; il backend rimane autorevole.

- Base unit: integer minor units per valuta oppure Decimal, con scelta esplicita.
- Precisione massima per quantita, prezzo, aliquota e importi; limiti dei valori rappresentabili.
- Rounding mode e punto di arrotondamento: riga, imponibile, documento; ordine di applicazione di sconti, IVA, ritenute e altri componenti.
- Gestione esplicita di zero, negativi, quantita frazionarie e valute a scala diversa, se supportate.
- Golden tests condivisi client/backend. JavaScript Number non e ammesso come risultato fiscale definitivo.

11. Contratto FatturaPA/SDI

- Il frontend consuma un contratto fiscale backend versionato.
- Il contratto deve indicare versione specifiche FatturaPA/XSD supportata, codici di scarto gestiti, mapping stato backend <-> SDI, retry, idempotenza, correlazione invio/esito, notifiche duplicate/tardive e conservazione.
- La versione concreta degli XSD e delle mapping tables deve essere presente nel repository e referenziata dalla release.
- Il frontend non implementa la semantica fiscale definitiva dello SDI.
- Submission fiscale e numerazione fiscale non sono mutation offline-optimistic.

12. Realtime

```
Evento realtime -> validate schema
        -> verify session/channel
        -> verify organization_id
        -> verify entity id/version
        -> discard duplicate/out-of-order
        -> refetch/reconcile
```

- Canali non autorizzati non devono ricevere eventi cross-tenant.
- La ricezione di un evento non equivale ad accettazione fiscale o persistenza definitiva.

13. Security e CSP

Baseline CSP testabile e intenzionalmente restrittiva:

```
default-src 'self';
script-src 'self' 'nonce-...';
object-src 'none';
```

```
base-uri 'none';
frame-ancestors 'none';
form-action 'self';
connect-src 'self' https://<allowlist>;
worker-src 'self';
img-src 'self' data: blob:;
font-src 'self';
style-src 'self' 'nonce-...';
```

- Vietare eval, script inline non necessari e HTML non attendibile.
- Threat model obbligatorio: XSS, CSRF, token theft, cross-tenant, replay, manipolazione outbox, supply chain, perdita dispositivo, abuso API.
- Security acceptance: SBOM/dependency scan, secret scan, CSP enforcement, XSS/CSRF/injection/session tests, RLS matrix e benchmark OWASP ASVS 5.0 applicabile con esclusioni motivate.

14. Observability e incident response

- Sentry o equivalente per error monitoring client-side.
- OpenTelemetry per tracing/metriche dove supportato; non assumere parita funzionale assoluta tra OpenTelemetry browser e Sentry.
- CorrelationId/requestId comuni tra frontend, API, backend transaction, outbox e audit.
- Redaction obbligatoria di email, codice fiscale, XML, token, payload outbox e numeri documento nei log/telemetria salvo casi formalmente autorizzati.
- Incident response: audit incidente, revoca sessioni/device, rotazione segreti, containment, evidenza forense, classificazione rischio, runbook e supporto al data-breach assessment.

15. Acceptance Criteria

ID	Given / When	Then verificabile
AC-RLS-01	U appartiene ad A; query oggetto di B	0 righe; nessun evento realtime; requestId tracciato
AC-RLS-02	U invia organization_id=B	Backend usa membership U; operazione rifiutata o reindirizzata ad A
AC-IDEM-01	Stessa mutation + stessa key ripetuta	Stesso risultato logico; una sola write/effect
AC-IDEM-02	Stessa key + payload diverso	IDEMPOTENCY_KEY_REUSE_CONFLICT; nessuna seconda mutation
AC-OFF-01	Rete assente; entita nella allowlist offline	Outbox pending; UI non dichiara successo fiscale
AC-OFF-02	Crash durante processing	Lease/fencing impediscono double-write; retry senza duplicazione
AC-CONF-01	Versione locale diversa dal server	Conflitto esplicito secondo matrice; nessun overwrite silenzioso
AC-MONEY-01	Stesso golden input client/backend	Totali e rounding identici; test passa
AC-SEC-01	Payload XSS/CSP violation	Script non eseguito; telemetria redatta
AC-REC-01	Quota critica/device loss	Alert + recovery/export; pending non cancellato

AC-SDI-01	Webhook duplicato/fuori ordine	Deduplica; stato monotonicamente valido; audit

16. Offline Mutation Allowlist

Operazione	Offline	Regola
Customer draft	DA DEFINIRE	Consentita solo se esplicitamente inclusa nella release matrix
Order draft	SI	Outbox; nessuna conseguenza fiscale definitiva
Invoice draft	SI	Bozza non inviata; validazione fiscale backend al submit
Invoice submission / SDI	NO	Solo online; backend autorevole
Fiscal numbering	NO	Solo backend transaction
SDI state mutation	NO	Solo provider/backend flow
Payment registration	DA DEFINIRE	Dipende dal modello contabile e dal contratto backend
Master-data mutation	DA DEFINIRE	Strategia esplicita per entita e conflitto

17. Schema e payload versioning

- RxDB schema migrations devono essere deterministiche, ripetibili e testate su dataset rappresentativi.
- Ogni item outbox deve avere operation + payloadVersion + schemaVersion.
- L'app deve sapere leggere e processare mutation pending prodotte da versioni precedenti supportate, oppure deve fornire una migrazione esplicita prima del processing.
- Un upgrade che rende incompatibile un payload pending deve bloccare il processing con recovery guidato, mai scartare silenziosamente la mutation.

18. Audit e integrita

- Audit record con timestamp server-side, actor/user, organization, entity, entity_version, operation, result, requestId/correlationId e schema version.
- Definire retention, access control, export authorization e immutabilita/log integrity secondo il dominio.
- Conflitti, replay idempotenti, errori permanenti, recovery e transizioni SDI devono essere auditabili.

19. CI/CD e Definition of Done

- Lockfile verificato; SBOM e dependency audit senza vulnerabilita bloccanti.
- Migrazioni e schema RxDB ripetibili; contract/API tests verdi.
- Test RLS cross-tenant su SELECT/INSERT/UPDATE/DELETE/RPC/Realtime.
- Test outbox, conflict matrix, idempotency reuse, quota, crash, fencing, tab multipli e recovery.
- Test E2E offline con Playwright e browser/device matrix.
- CSP enforcement, ASVS evidence, redaction e alert verificati.
- Restore backend eseguito con RPO/RTO misurati e confrontati con gli SLO approvati.

- Change log, runbook, rollback e approvazioni engineering/security/domain completi.
- Nessun go-live con finding critico aperto o con test non riproducibili.

RPO, RTO, max retry, max outbox age, storage thresholds, SLO di latenza e altri valori quantitativi devono essere fissati nel repository e approvati da engineering/operations/domain; la specifica non li inventa.

20. Gate di go-live

Gate	Condizione
Backend	Contratti API, transazioni, error handling e recovery verificati
RLS / Multi-tenant	Test cross-tenant verdi per DB, RPC e Realtime
Fiscalita / SDI	Contratto fiscale versionato, XSD e mapping testati, esiti verificati
Security	ASVS evidence, pentest/assessment, CSP e SBOM review chiusi
Privacy	Matrice retention/storage/device recovery approvata; processi privacy verificati
Recovery	Restore eseguito; RPO/RTO entro target
Observability	Alerting, redaction, correlation e incident runbook operativi
Release	Rollback provato; dataset e risultati test firmati; nessun finding critico aperto

21. Decisione finale

VERDETTO: la Specifica Architetturale Frontend ERP v3.1 e VALIDATA come Implementation Contract e base di sviluppo enterprise. La versione incorpora le correzioni emerse dalla validazione della v2.0/v3.0 e rende espliciti i principali vincoli di sicurezza, offline, idempotenza, fiscalita, recovery e test.

La v3.1 non costituisce certificazione, non sostituisce audit indipendenti e non autorizza il go-live senza evidenze di accettazione e approvazioni competenti. Ogni release deve essere riproducibile da commit, lockfile, dataset, ambiente e risultati di test firmati.

FINE DEL DOCUMENTO